

Azure 환경에서의 UEBA 기반 사용자 행동 프로파일링



저자 1 (학번 최두환)
저자 2 (학번 심여준)
저자 3 (학번 유지호)

지도교수 : 최윤호

목 차

1. 서론	1
1.1 개발 배경	1
1.2 기존 문제점	1
1.3 개발 목표	1
2. 개발 배경	1
2.1 개발 배경 항목-1	1
2.2 개발 배경 항목-2	1
3. 개발 내용	1
3.1 개발 내용 절-1	1
3.1.1 개발 내용 절-1-1	1
3.1.2 개발 내용 절-1-2	1
3.2 개발 내용 절-2	1
3.3 개발 내용 절-3	1
3.3.1 개발 내용 절-3-1	1
3.3.2 개발 내용 절-3-2	1
4. 개발 결과 분석 및 평가	1
5. 결론 및 향후 개발 방향	1
6. 참고 문헌	1

1. 개발 배경 및 필요성

1.1 클라우드 보안 환경의 변화

클라우드 환경의 확산과 함께, 기업의 IT 자산은 더 이상 물리적 경계(Firewall, VPN 등)에 의해 보호되지 않는다. 특히 AWS와 같은 클라우드 플랫폼은 다양한 위치와 디바이스에서 리소스에 접근할 수 있는 환경을 제공하므로, 전통적인 경계 기반 보안 모델은 실효성을 상실하고 있으며, 신뢰할 수 없는 네트워크를 전제로 한 '제로 트러스트' 보안 아키텍처가 글로벌 보안 표준으로 자리 잡고 있다.

1.2 제로 트러스트 보안 모델의 부상

이러한 변화에 대응하기 위해 등장한 제로 트러스트(Zero Trust) 모델은 "아무도 신뢰하지 않고, 항상 검증한다(Never Trust, Always Verify)"는 철학을 기반으로 한다. 제로 트러스트는 다음과 같은 3대 원칙을 핵심으로 한다:

1. 명확한 사용자 확인 (Verify Explicitly)
2. 최소 권한 원칙 적용 (Use Least Privileged Access)
3. 지속적 모니터링 및 리스크 기반 접근 제어 (Assume Breach)

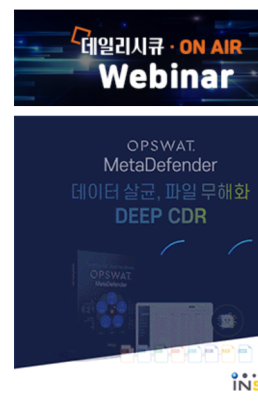
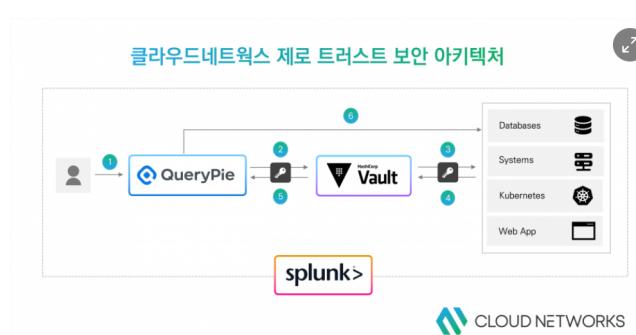
이를 효과적으로 구현하기 위해서는 사용자 및 엔터티의 모든 행동을 정량적으로 분석하고 이상 징후를 탐지할 수 있는 체계, 즉 UEBA(User and Entity Behavior Analytics)가 반드시 필요하다.

클라우드 보안의 새로운 기준, 클라우드네트워크스가 제안하는 제로 트러스트 전략

ⓒ 김민권 기자 | © 승인 2025.04.01 13:51



제로 트러스트 보안 모델이 클라우드 보안의 필수 요소로 자리 잡고 있어 클라우드 보안의 혁신을 이끄는 클라우드네트워크스



[그림 1] 제로 트러스트 관련 기사

(출처: <https://www.dailysecu.com/news/articleView.html?idxno=164939>)

2. 기존 보안 체계의 문제점

현재의 보안 운영 체계는 여러 측면에서 한계를 보이고 있으며, 이는 제로 트러스트 보안 모델의 원칙과도 충돌하는 요소들이 존재합니다.

첫째, 대부분의 보안 시스템은 룰 기반 탐지(rule-based detection)에 의존하고 있습니다. 이는 사전에 정의된 이벤트 패턴과 일치할 경우에만 경고가 발생하는 방식으로, 알려진 공격에는 효과적일 수 있으나, 지속적으로 진화하는 신종 위협이나 정상 행위로 위장된 공격에 대해서는 탐지력이 현저히 떨어지는 문제가 있습니다. 제로 트러스트의 핵심 원칙인 지속적 검증(Continuous Verification) 측면에서 볼 때, 이러한 정적 룰 기반 탐지는 사용자 및 엔터티의 실제 행위를 기반으로 한 이상 탐지를 수행하기 어렵습니다.

둘째, 기존 시스템은 사용자 계정에 권한을 부여한 후 장기간 변경 없이 유지하는 경향이 있습니다. 이는 '필요할 때만, 최소한의 권한으로 접근을 허용한다'는 최소 권한 원칙(Least Privilege Access)에 어긋나며, 권한이 과도하게 유지될 경우 내부자 위협이나 계정 탈취 시 더 큰 피해를 유발할 수 있습니다.

셋째, 보안 모니터링 체계가 로그 소스별로 분산되어 있어 전사적 관점에서 통합 분석을 수행하는 데 어려움이 있습니다. Azure AD, O365, Defender, 네트워크 등 각기 다른 위치에서 생성되는 로그들이 개별적으로 관리되며, 이로 인해 사용자 행위의 전체적인 컨텍스트를 파악하기 어려워 복합적 공격 탐지에 한계가 발생합니다. 이는 제로 트러스트가 요구하는 상황 기반 판단 및 정책 적용(Context-aware Policy Enforcement)을 실현하는 데 장애 요소가 됩니다.

마지막으로, 많은 조직이 보안 경고 발생 이후에도 대응을 수작업에 의존하는 경우가 많습니다. 즉, 이상 징후 탐지는 이루어지더라도 실질적인 조치(계정 잠금, 세션 차단 등)가 지연되며, 이는 공격 확산을 차단하는 데 있어 치명적인 취약점이 됩니다. 제로 트러스트 모델이 강조하는 위험 기반의 자동 대응(Automated Threat Response) 측면에서 보면, 이러한 대응 자동화 부족은 실질적인 보안 효과를 떨어뜨리는 주요 원인입니다.

이러한 문제들을 극복하기 위해서는 사용자 및 엔터티의 행위 기반 분석을 중심으로 한 UEBA 기술 도입과, 이를 AWS의 CloudTrail, GuardDuty, Detective와 같은 네이티브 보안 서비스들과 연계하는 전략이 필요합니다.

3. 개발 목표 및 내용

3.1 개발 최종 목표

본 개발은 Amazon Web Services(AWS) 클라우드 환경을 기반으로, 사용자 및 엔터티의 정상적인 행위 패턴을 정량적으로 모델링하고, 이를 기준으로 이상 징후를 탐지할 수 있는 지능형 UEBA(User and Entity Behavior Analytics) 시스템을 설계·구현하는 것을 궁극적인 목표로 한다. 이를 통해 클라우드 기반 인프라에 적합한 제로 트러스트 보안 모델을 기술적으로 실현하고, 보안 관제의 정확성, 대응 속도, 자동화 수준을 전반적으로 고도화하고자 한다.

특히, AWS의 CloudTrail, GuardDuty, Detective 등 네이티브 보안 서비스와 연계하여 사용자 및 엔터티의 실시간 행위 기반 위험 평가 체계(Risk Scoring System)를 구축함으로써, 사전 정의된 룰 기반 탐지 방식의 한계를 극복하고, 보다 정밀하고 유연한 접근 통제 및 사고 대응 체계를 구현하는 것이 본 개발의 핵심 지향점이다.

3.2 세부 추진 내용

3.2.1 AWS 기반 통합 로그 수집 체계 구축

- AWS CloudTrail, Amazon GuardDuty, AWS Config, VPC Flow Logs, AWS CloudWatch Logs 등 다양한 보안 로그 및 이벤트 데이터를 통합 수집
- Amazon S3 또는 CloudWatch Logs를 중심으로 로그 저장소를 구성하고, CloudWatch Logs Insights 또는 Amazon Athena를 활용한 쿼리 환경 구축

3.2.2 사용자 및 엔터티 정상 행위 프로파일링

- 시간대별 API 호출 패턴, 지리적 접근 위치, 디바이스 정보(User-Agent), 인증 방식(MFA 포함) 등 다양한 요소를 기반으로 사용자와 엔터티의 정상 행동을 모델링
- IAM 사용자 및 역할별 baseline 모델을 정량화하여 행위 기반 이상 탐지의 기준으로 활용

3.2.3 이상 행위 탐지 알고리즘 설계

- 초기에는 CloudTrail 및 GuardDuty 데이터를 활용한 룰 기반 탐지 로직 구성 (예: 지역 변경, 과도한 API 호출 등)
- 중·후반기에는 Amazon SageMaker를 활용한 비지도 학습 기반 이상 탐지 모델(Isolation Forest, Autoencoder 등)을 적용하여 정형화되지 않은 위협 탐지 기능 강화
- 다양한 로그 및 이벤트 소스를 상관 분석하여 복합 행위 기반 탐지 로직 구성

3.2.4 위험 점수화(Risk Scoring) 및 UEBA 기반 정책 엔진 구현

- 탐지된 이상행위에 대해 행위의 유형, 빈도, 지속성, 자산 민감도 등을 고려한 가중치

기반 Risk Score 산출

- 사용자/엔터티 단위로 누적 위험 점수를 관리하고, 일정 기준 초과 시 경고 생성, 접근 제한, 추가 인증 등 정책 자동 연계

3.2.5 자동화 대응 체계 구축 (Amazon EventBridge 및 Lambda 등)

- Amazon EventBridge, AWS Lambda, AWS Systems Manager를 연계하여 이상행위 탐지 시 자동화된 대응 시나리오 실행 체계 구성
- 제로 트러스트 원칙에 기반한 리스크 중심의 실시간 정책 반영 및 접근 제어 구현
예: IAM 사용자 비활성화, 임시 권한 제한, 관리자에게 Amazon SNS 또는 AWS Chatbot을 통한 실시간 알림

4. 기대효과

본 개발을 통해 구축될 AWS 기반 사용자 및 엔터티 행위 분석(UEBA) 시스템은 제로 트러스트 보안 원칙을 실질적으로 구현할 수 있는 핵심 보안 모듈로 작동하며, 다음과 같은 기술적, 운영적, 전략적 효과를 기대할 수 있다.

4.1 기술적 기대 효과

4.1.1 정량 기반 보안 탐지 고도화

전통적인 룰 기반 탐지를 넘어, 사용자 및 엔터티의 정상 행동을 기준으로 실시간 이상 행위를 정량적으로 탐지함으로써, 신규 및 지능형 위협(APT, 계정 탈취, 내부자 공격 등)에 대한 탐지 능력을 획기적으로 향상시킨다. AWS의 CloudTrail, GuardDuty, VPC Flow Logs 등의 데이터를 기반으로 고도화된 분석이 가능하다.

4.1.2 리스크 중심의 보안 정책 적용 가능

Risk Scoring 체계를 통해 개별 사용자 및 리소스의 보안 상태를 지속적으로 평가하고, 그 결과에 따라 IAM 정책 제어, 접근 제한, MFA 재요구 등 상황 기반의 보안 정책(Context-aware Access Control)을 동적으로 적용할 수 있다.

4.1.3 보안 운영 자동화 및 대응 속도 향상

Amazon EventBridge, AWS Lambda, AWS Systems Manager, SNS 등을 연계하여 경고-분석-대응의 자동화 체계를 구축함으로써, 이상행위 발생 시 수작업 개입 없이 실시간 대응이 가능하며, 보안 사고의 확산 방지 및 복구 속도가 비약적으로 향상된다.

4.2 운영 및 조직적 기대효과

4.2.1 보안 관제 효율성 제고

CloudTrail, CloudWatch Logs, GuardDuty 등에서 발생하는 대량의 보안 로그에 대해 이상행위 기반 우선순위 분류 및 경고 자동화가 가능하여, 보안 인력의 판단 정확도와 대응 효율성을 동시에 향상시킨다.

4.2.2 제로 트러스트 보안체계 실현 기반 마련

본 시스템은 사용자 중심의 지속적 검증, 리스크 기반 통제, 자동화된 대응을 기술적으로 실현함으로써, 조직 차원의 제로 트러스트 보안 아키텍처 전환을 위한 핵심 기술 인프라로 작용한다.

4.2.3 보안 사고 예방 및 경영 리스크 저감

이상행위에 대한 조기 탐지와 신속한 대응을 통해 실제 보안 사고 발생 가능성을 현저히 낮추며, 금전적 손실, 신뢰도 하락, 법적 책임 등 조직의 경영 리스크를 실질적으로 감소시킬 수 있다.

4.3 전략적 파급 효과

4.3.1 보안 거버넌스 및 규제 대응 역량 강화

사용자 행위 기반의 정량적 위험 평가 및 정책 로그 기록은 ISMS, NIS, GDPR, ISO 27001 등 주요 보안 인증과 법규 준수 요건을 충족하는 데 유리하게 작용하며, 감사 및 보고 시에도 객관적인 증적 데이터로 활용될 수 있다.

4.3.2 유사 시스템 구축을 위한 래퍼런스 확보

AWS의 네이티브 보안 서비스들과 연계된 UEBA 시스템 구축 사례는 향후 조직 내외 유사 보안 시스템 구축 시 기술적 참조 모델 및 아키텍처 기준점으로 활용 가능하며, 보안 체계의 수평적 확장성을 확보하는 데 기여할 수 있다.

5. 수행 계획

5.1 역할 분담

이름	해당 역할
최두환	기획 및 인프라 개발 - 통합 로그 수집 시스템 구축 - 분석 모델 개발 - 이상행위 대응 체계 개발
심여준	프론트 개발 - 웹 디자인 구상 - React를 활용한 프론트엔드 개발 - UEBA 대시보드 구현
유지호	백엔드 개발 - SQL 데이터베이스 및 API 설계 - FastAPI를 통한 백엔드 개발 - 시스템 통합

5.2 개발 일정

개발 내용	추진일정													
	5		6			7			8		9			10
기획 및 설계														
착수보고서 작성														
로그 통합 수집 시스템 구축														
SQL 데이터베이스 구축														
백엔드 개발														
프론트엔드 개발														
Data Pre-processing														
Feature Extraction														
프로파일링 모델 개발														
Risk Scoring 모델 개발														
중간 보고서 작성														
모델 트레이닝														
시스템 통합														
최종 보고서 작성														
발표 준비														